Aonde você quer chegar?

Vai com a

UniCesumar

EAD, SEMIPRESENCIAL E PRESENCIAL

UniCesumar
EDUCAÇÃO PRESENCIAL E A DISTÂNCIA

AULA 02

Ethical Hacker

Ameaças, Ataques e Fundamentos de Segurança Cibernética



Professor Rodolfo Terra | linkedin.com/in/rodolffoterra/ | github.com/rodolffoterra

UniCesumar
EDUCAÇÃO PRESENCIAL E A DISTÂNCIA

BLOCO 01

Retomada e conceitos



Professor Rodolfo Terra | linkedin.com/in/rodolffoterra/ | github.com/rodolffoterra/

UniCesumar
EDUCAÇÃO PRESENCIAL E A DISTÂNCIA

O que vamos aprender nesta aula?

Nesta aula vamos entender como surgem as ameaças, quais vulnerabilidades podem ser exploradas, como os ataques afetam pessoas e organizações e por que a proteção depende de pessoas, processos e tecnologia.



1 Retomada e conceitos fundamentais

- Revisar os pilares CIA
- Introduzir ameaça, vulnerabilidade, ataque e risco

5 minutos

2 Ameaças e riscos

- O que é ameaça
- O que é vulnerabilidade
- Como ocorre um ataque
- O que é risco e como avaliar

20 minutos

3 Malwares e ataques

- O que é malware e vírus
- Principais tipos de malware
- Formas de ataque mais comuns

15 minutos

4 Pessoas e impactos

- O fator humano
- Riscos para as pessoas
- Riscos para as organizações
- Impactos no negócio

15 minutos

5 Políticas e prevenção

- Políticas de Segurança da Informação
- Pessoas, processos e tecnologia
- Gerenciamento contínuo de riscos
- Como tratar os riscos

25 minutos

6 Discussão e encerramento

- Aplicação dos conceitos
- Situação-problema
- Principais aprendizados
- Próximos passos

10 minutos

Ao final **desta aula, você será capaz de:**

- Identificar ameaças, vulnerabilidades, ataques e riscos.
- Relacionar esses conceitos com a tríade CIA.
- Reconhecer os principais tipos de malware e formas de ataque.
- Compreender como pessoas e organizações podem ser afetadas.
- Entender a importância das políticas de Segurança da Informação.
- Perceber por que o treinamento e a conscientização são essenciais.
- Compreender que a segurança depende da integração entre pessoas, processos e tecnologia.
- Reconhecer que o gerenciamento de riscos é uma atividade contínua.

Professor Rodolfo Terra | linkedin.com/in/rodolffoterra/ | github.com/rodolffoterra/

UniCesumar
EDUCAÇÃO PRESENCIAL E A DISTÂNCIA

Retomando a Tríade CIA

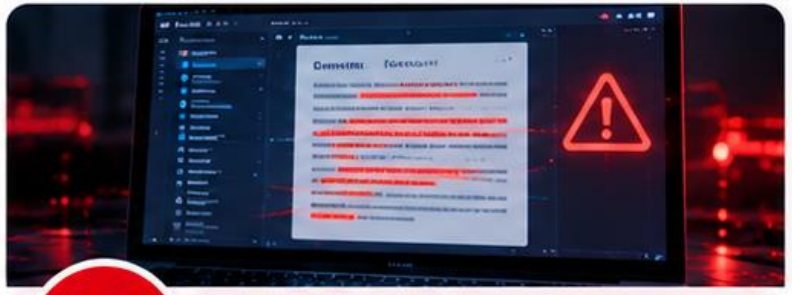
A segurança da informação se **baseia em três princípios fundamentais** que devem ser **protegidos:**



Confidencialidade

Garantir que as informações sejam acessadas apenas por pessoas autorizadas.

Exemplo
Vazamento de dados de clientes expõe informações sensíveis, como CPF e dados de pagamento.



Integridade

Garantir que as informações sejam corretas, completas e não sejam alteradas de forma não autorizada.

Exemplo
Alteração indevida de registros financeiros gerando valores incorretos em relatórios da empresa.



Disponibilidade

Garantir que as informações e os recursos estejam disponíveis quando necessário para as pessoas autorizadas.

Exemplo
Sistema indisponível por um ataque de negação de serviço (DDoS), impedindo o acesso de usuários.

O que pode comprometer esses princípios?

- Malwares
- Ataques
- Ações humanas não intencionais
- Falhas de configuração e gestão de processos
- Ameaças internas e externas

Professor Rodolfo Terra | linkedin.com/in/rodolffoterra/ | github.com/rodolffoterra/

UniCesumar
EDUCAÇÃO PRESENCIAL E A DISTÂNCIA

BLOCO 02

Ameaças e riscos



Professor Rodolfo Terra | linkedin.com/in/rodolffoterra/ | github.com/rodolffoterra/

UniCesumar
EDUCAÇÃO PRESENCIAL E A DISTÂNCIA

Ameaça, Vulnerabilidade, Ataque e Risco

Esses quatro conceitos estão diretamente relacionados e serão utilizados durante toda a disciplina.



Ameaça

É qualquer evento, intencional ou não intencional, que pode causar um dano à informação, aos sistemas ou à organização.

Vulnerabilidade

É uma fraqueza em sistemas, processos, pessoas ou tecnologia que pode ser explorada por uma ameaça.

Ataque

É a ação que explora uma vulnerabilidade com o objetivo de comprometer a segurança da informação.

Risco

É a possibilidade de que uma ameaça explore uma vulnerabilidade e cause um impacto negativo à organização.

Professor Rodolfo Terra | linkedin.com/in/rodolffoterra/ | github.com/rodolffoterra/

UniCesumar
EDUCAÇÃO PRESENCIAL E A DISTÂNCIA

O que é uma ameaça?

Ameaça é qualquer evento, intencional ou não intencional, que tem o potencial de causar um dano à informação, aos sistemas ou à organização.

Ameaça representa uma **possibilidade** de **dano** e não significa que um ataque já aconteceu.

Exemplo

A existência de criminosos digitais na Internet é uma ameaça, mesmo que nenhuma tentativa de ataque tenha ocorrido ainda.



Criminosos digitais

Hackers, grupos criminosos e cibercriminosos.



Malware

Vírus, worms, ransomware e outros códigos maliciosos.



Falhas humanas

Erros, configurações incorretas e uso inadequado dos recursos.





Engenharia social

Phishing, fraudes e manipulação de pessoas.

Exploração de vulnerabilidades

Aproveitamento de falhas em sistemas e aplicações.

Eventos físicos

Desastres naturais, incêndios, quedas de energia, entre outros.

Ameaças internas

Colaboradores mal-intencionados ou sem os devidos cuidados.

UniCesumar
EDUCAÇÃO PRESENCIAL E A DISTÂNCIA

O que é uma vulnerabilidade?

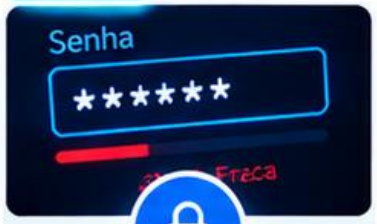
Vulnerabilidade é uma **fragilidade em um sistema, tecnologia, pessoa ou processo** que pode ser explorada por uma ameaça para causar um impacto negativo.

Vulnerabilidades por si só não causam danos.

Elas existem até que sejam exploradas por uma ameaça, gerando um ataque.



Exemplos de vulnerabilidades



Senha fraca

Uso de senhas simples ou facilmente descobertas, como 123456 ou datas de aniversário.

PESSOAS



Software desatualizado

Sistemas e aplicações sem atualizações de segurança, com falhas já conhecidas.

TECNOLOGIA



Permissões excessivas

Usuários com mais acessos do que o necessário para realizar suas atividades.

TECNOLOGIA



Configuração incorreta

Equipamentos ou aplicações configurados de forma inadequada, expondo serviços desnecessários.

TECNOLOGIA



Usuário sem treinamento

Falta de conscientização sobre riscos, facilitando a ação de ataques como phishing e engenharia social.

PESSOAS



Processo inadequado

Procedimentos mal definidos ou inexistentes que aumentam a exposição a riscos.

PROCESSOS

UniCesumar
EDUCAÇÃO PRESSNCIAL E A DISTÂNCIA

Quando uma vulnerabilidade se transforma em ataque?

Uma vulnerabilidade só se torna um ataque quando alguém a identifica e realiza ação para explorá-la, com o objetivo de comprometer a segurança da informação.

Lembre-se:
Vulnerabilidade é uma fragilidade que **existe.** Ataque é a ação que **explora** essa fragilidade.

1 Ameaça (atacante)



Um atacante identifica possíveis alvos e busca vulnerabilidades para explorar.

2 Vulnerabilidade existente



O servidor está com um software desatualizado, que possui uma vulnerabilidade conhecida.

3 Exploração da falha



O atacante executa uma ação para explorar a vulnerabilidade, utilizando um exploit (código ou técnica específica).

4 Comprometimento do sistema



A exploração é bem-sucedida e o atacante obtém acesso, comprometendo o sistema e podendo causar danos.

Vulnerabilidade (fragilidade)
- Existe antes do ataque.
- É uma condição ou falha.
- Não causa dano por si só.

≠

Ataque (ação)
- É a ação de explorar a vulnerabilidade.
- Só acontece quando há um atacante.
- Pode causar dano ao sistema ou à organização.

Professor Rodolfo Terra | linkedin.com/in/rodolffoterra/ | github.com/rodolffoterra/

UniCesumar
EDUCAÇÃO PRESENCIAL E A DISTÂNCIA

O que é risco em Segurança da Informação?

Risco é a possibilidade de que uma **ameaça** explore uma **vulnerabilidade** e cause um **impacto** negativo aos ativos da organização, considerando o **contexto** e as **consequências** desse impacto.

O risco não é apenas a existência da vulnerabilidade, mas a combinação entre a **probabilidade** de ocorrer e o **impacto** que pode causar.

1 Ameaça



Exemplo: criminoso digital que busca acesso não autorizado aos sistemas da empresa.

2 Vulnerabilidade



Exemplo: sistema com versão antiga, sem correções de segurança.

3 Possível impacto



Exemplo: exposição de dados sensíveis de clientes, gerando danos financeiros e de reputação.

4 Risco



Resultado da combinação entre a probabilidade de ocorrer e o impacto para a organização.

Fórmula didática:

Risco ≈ Probabilidade × Impacto

O risco depende do contexto

A mesma vulnerabilidade pode representar riscos diferentes, dependendo da importância do ativo e das consequências.

Risco alto
Sistema crítico com dados pessoais de clientes.
Alto impacto para o negócio.

Risco médio
Sistema interno com dados operacionais.
Impacto moderado.

Risco baixo
Ambiente de testes sem dados reais.
Baixo impacto.

Professor Rodolfo Terra | linkedin.com/in/rodolffoterra/ | github.com/rodolffoterra/

UniCesumar
EDUCAÇÃO PRESENCIAL E A DISTÂNCIA

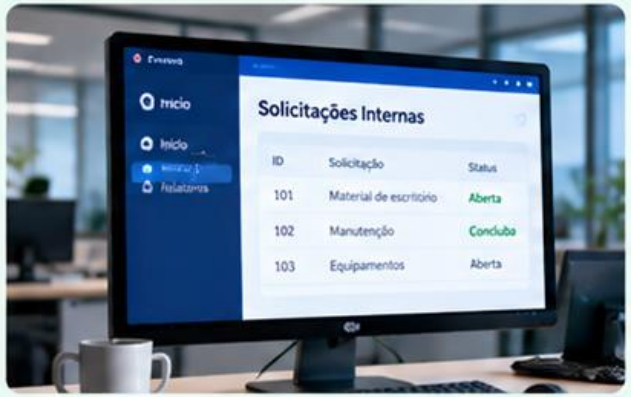
Duas vulnerabilidades, riscos diferentes

A mesma vulnerabilidade pode gerar **riscos diferentes**, dependendo do contexto, da importância do sistema e das consequências de um possível impacto.

O risco depende de fatores como **exposição, criticidade do ativo, tipos de dados, impacto** no negócio e **probabilidade** de exploração.

EXEMPLO 1 — Sistema interno de baixa criticidade

Sistema de controle de solicitações de materiais, utilizado apenas por funcionários, na rede interna.



Vulnerabilidade (exemplo)
Software desatualizado (versão antiga).

Contexto
- Acesso apenas na rede interna.
- Dados de baixa sensibilidade.
- Não é um sistema crítico.

Possível impacto
- Indisponibilidade temporária.
- Perda de dados não críticos.
- Necessidade de reinstalação.

Nível de risco BAIXO

EXEMPLO 2 — Sistema de pagamentos exposto à Internet

Plataforma de pagamentos online, acessível por clientes via Internet, que processa dados financeiros.



Vulnerabilidade (exemplo)
Software desatualizado (versão antiga).

Contexto
- Acesso pela Internet.
- Dados financeiros de clientes.
- Sistema crítico para o negócio.

Possível impacto
- Roubo de dados financeiros.
- Fraudes e prejuízos financeiros.
- Danos à reputação e perda de clientes.
- Multas e sanções regulatórias.

Nível de risco ALTO

Conclusão

A vulnerabilidade é a mesma, mas o risco é diferente, pois o **contexto**, a **exposição** e o impacto potencial mudam completamente.

Principais fatores que alteram o risco

- Exposição do sistema (interno ou Internet).
- Importância do ativo para o negócio (criticidade).
- Tipo de dados envolvidos.
- Possíveis consequências do impacto.
- Probabilidade de exploração.
- Requisitos legais e regulatórios.

Professor Rodolfo Terra | linkedin.com/in/rodolffoterra/ | github.com/rodolffoterra/

UniCesumar
EDUCAÇÃO PRESENCIAL E A DISTÂNCIA

Uma casa, quatro conceitos

A mesma situação do dia a dia nos ajuda a entender a diferença entre ameaça, vulnerabilidade, ataque, impacto e risco.

A analogia da casa mostra como uma **ameaça** pode explorar uma **vulnerabilidade**, resultando em um **ataque**, que gera um **impacto** e aumenta o **risco**.



1 Ameaça

Um ladrão no bairro.

Representa uma possibilidade de dano. A ameaça existe, mesmo que nada aconteça.

2 Vulnerabilidade

Janela aberta.

É uma fragilidade na casa que pode ser explorada pelo ladrão.

3 Ataque

Entrada indevida.

O ladrão aproveita a janela aberta para entrar na casa.

4 Impacto

Roubo do computador.

Consequência do ataque, gerando perda de um bem importante.

5 Risco

Probabilidade e impacto.

O risco considera a chance de o ladrão conseguir entrar e o impacto caso isso ocorra (perda do computador e de dados importantes).

1 Ameaça
Possibilidade de dano (ladrão no bairro).

2 Vulnerabilidade
Fragilidade que pode ser explorada (janela aberta).

3 Ataque
Ação que explora a vulnerabilidade (entrada na casa).

4 Impacto
Consequência do ataque (roubo do computador).

5 Risco
Combinação entre probabilidade de ocorrer e o impacto causado.

Professor Rodolfo Terra | linkedin.com/in/rodolffoterra/ | github.com/rodolffoterra/

UniCesumar
EDUCAÇÃO PRESENCIAL E A DISTÂNCIA

BLOCO 03

Malwares e ataques





Professor Rodolfo Terra | linkedin.com/in/rodolffoterra/ | github.com/rodolffoterra/

UniCesumar
EDUCAÇÃO PRESENCIAL E A DISTÂNCIA

BLOCO 3

Malwares e Formas de Ataque



Neste bloco, vamos explorar o universo dos **malwares** e conhecer as principais **formas de ataque digital,** entendendo como eles funcionam, quais são os seus objetivos e como podem comprometer a segurança dos sistemas e dos dados.

Malwares
Tipos, características e objetivos.

Formas de ataque
Técnicas utilizadas para explorar vulnerabilidades.

Objetivos
O que os atacantes buscam e como atuam.

Consequências
Impactos para pessoas, organizações e sociedade.

Prevenção
Boas práticas para reduzir a exposição a ataques.

Principais objetivos de aprendizagem

- Identificar os principais tipos de malwares.
- Compreender as diferentes formas de ataque.
- Reconhecer os objetivos dos atacantes.
- Analisar as possíveis consequências.
- Relacionar os conceitos com medidas de prevenção e mitigação.

Professor Rodolfo Terra | linkedin.com/in/rodolffoterra/ | github.com/rodolffoterra/

UniCesumar
EDUCAÇÃO PRESENCIAL E A DISTÂNCIA

Malware e vírus são a mesma coisa?

Não. Todo vírus é um malware, mas nem todo malware é um vírus.
Malware é um termo mais amplo que engloba diferentes tipos de software malicioso, sendo o vírus apenas um deles.

Malware é o termo geral para qualquer **software** projetado para causar **danos** ou realizar **ações maliciosas.**

MALWARE

Software malicioso que pode causar danos, roubar informações ou obter acesso não autorizado.

Vírus
Anexa-se a arquivos e se replica quando o arquivo é executado.

Worm (Verme)
Se replica automaticamente pela rede, sem necessidade de arquivo hospedeiro.

Cavalo de Troia
Disfarça-se de software legítimo para enganar o usuário e executar ações maliciosas.

Ransomware
Criptografa os dados da vítima e exige resgate para liberá-los.

Spyware
Monitora e coleta informações do usuário sem autorização.

Botnet
Transforma o dispositivo em um "zumbi" para executar ações remotas, como ataques DDoS.

Vírus

- É um tipo de malware.
- Precisa de um arquivo hospedeiro para se replicar.
- Normalmente é ativado quando o usuário executa o arquivo infectado.

Malware

- Categoria mais ampla.
- Inclui vírus, worms, trojans, ransomware, spyware, botnets e outros.
- Pode se espalhar de diferentes formas e causar diversos tipos de danos.

Conclusão

Vírus é um tipo específico de malware.
Existem muitos outros tipos de malware, cada um com características, formas de propagação e objetivos diferentes.

Principais objetivos dos malwares

- Roubar informações (dados pessoais, senhas, dados financeiros).
- Obter acesso não autorizado a sistemas.
- Causar danos, indisponibilidade ou perda de dados.
- Controlar dispositivos remotamente.
- Extorquir valores (ex.: ransomware).

Professor Rodolfo Terra | linkedin.com/in/rodolffoterra/ | github.com/rodolffoterra/

UniCesumar
EDUCAÇÃO PRESENCIAL E A DISTÂNCIA

Principais tipos de malware

Os malwares podem se apresentar de diferentes formas, com objetivos e impactos variados.

Todos os tipos de malware são projetados para causar algum tipo de **dano, roubar informações** ou obter **acesso não autorizado** a sistemas e dados.

1 Vírus



Anexa-se a arquivos ou programas legítimos e se replica quando o arquivo infectado é executado.

Possíveis impactos:
- Corrupção de arquivos.
- Perda de dados.
- Instabilidade do sistema.

2 Worm (Verme)



Se replica automaticamente pela rede, sem necessidade de ação do usuário, explorando vulnerabilidades para se espalhar.

Possíveis impactos:
- Propagação rápida.
- Consumo de recursos.
- Indisponibilidade de sistemas e redes.

3 Trojan (Cavalo de Troia)



Se disfarça de um software legítimo para enganar o usuário e, após a execução, permite a realização de ações maliciosas, como abrir portas de acesso para o atacante.

Possíveis impactos:
- Acesso não autorizado.
- Instalação de outros malwares.
- Roubo de dados.

4 Spyware



Monitora as atividades do usuário, coletando informações sem o seu conhecimento, como senhas, dados pessoais e hábitos de navegação.

Possíveis impactos:
- Vacamento de informações sensíveis.
- Perda de privacidade.
- Uso indevido de credenciais.

5 Ransomware



Criptografa os arquivos ou o sistema, impedindo o acesso aos dados, e exige o pagamento de um resgate para liberá-los.

Possíveis impactos:
- Indisponibilidade de dados e sistemas.
- Prejuízos financeiros.
- Interrupção das operações do negócio.

Importante

Cada tipo de malware possui um **objetivo** específico, mas todos representam riscos significativos para pessoas, organizações e para a sociedade.

Principais objetivos dos malwares
- Roubar informações (dados pessoais, financeiros, credenciais).
- Obter acesso não autorizado a sistemas.
- Causar danos, indisponibilidade ou perda de dados.
- Controlar dispositivos remotamente.
- Extorquir valores (ex.: ransomware).

Professor Rodolfo Terra | linkedin.com/in/rodolffoterra/ | github.com/rodolffoterra/

UniCesumar
EDUCAÇÃO PRESENCIAL E A DISTÂNCIA

Ransomware: quando a empresa perde acesso aos dados

O ransomware é um tipo de **malware** que **criptografa** os arquivos e sistemas da empresa, impedindo o **acesso** aos **dados** e exigindo o pagamento de um **resgate** para liberá-los.

1 Empresa operando normalmente



Os colaboradores utilizam os sistemas normalmente para realizar as atividades do dia a dia.

2 Infecção por ransomware



O malware é executado, geralmente por meio de um e-mail malicioso ou de uma vulnerabilidade explorada.

3 Sistemas inacessíveis



Os arquivos e sistemas ficam criptografados e inacessíveis, paralisando as operações da empresa.

4 Exigência de resgate



Os criminosos exigem o pagamento de um resgate para fornecer a chave de descriptografia.

Consequências para o negócio

- Interrupção das operações.
- Perda de receitas.
- Danos à reputação.
- Custos com recuperação e suporte especializado.
- Possível perda definitiva de dados.

Relação com a Tríade CIA

Confidencialidade
Pode ser comprometida caso os dados sejam expostos.

Integridade
Os dados podem ser alterados ou corrompidos durante o ataque.

Disponibilidade
É impactada diretamente, pois os dados e sistemas ficam inacessíveis.

Como reduzir o risco

- Realizar backups regulares e testados.
- Manter sistemas atualizados.
- Utilizar soluções de segurança (antivírus, EDR).
- Capacitar os usuários contra e-mails maliciosos.
- Implementar políticas de acesso e monitoramento.

Professor Rodolfo Terra | linkedin.com/in/rodolffoterra/ | github.com/rodolffoterra/

UniCesumar
EDUCAÇÃO PRESENCIAL E A DISTÂNCIA

Como os ataques chegam às vítimas?

Os ataques podem chegar às vítimas por diferentes caminhos, explorando tanto fragilidades técnicas quanto comportamentais.

Os atacantes utilizam diversas **técnicas** para entregar malwares ou explorar vulnerabilidades, aproveitando oportunidades em **pessoas, sistemas e processos.**

1 E-mail malicioso



O atacante envia um e-mail com um link ou anexo malicioso, que ao ser aberto pode instalar um malware ou direcionar para um site fraudulento.

Possíveis impactos:
- Instalação de malwares.
- Roubo de credenciais.
- Acesso não autorizado ao sistema.

2 Sistema desatualizado



Sistemas e softwares desatualizados podem conter vulnerabilidades conhecidas que são exploradas por atacantes para obter acesso.

Possíveis impactos:
- Execução de códigos maliciosos.
- Controle remoto do sistema.
- Movimentação lateral na rede.

3 Senha fraca



Senhas simples ou reutilizadas podem ser facilmente descobertas por ataques de força bruta, vazamentos de dados ou outras técnicas.

Possíveis impactos:
- Acesso não autorizado.
- Roubo de informações.
- Comprometimento de outros sistemas.

4 Usuário enganado (Engenharia Social)



O atacante se passa por uma pessoa de confiança e induz o usuário a realizar ações, como clique em links, fornecimento de credenciais ou instalação de programas.

Possíveis impactos:
- Entrega de credenciais.
- Instalação de malwares.
- Acesso a informações sensíveis.

Importante

Os ataques podem combinar mais de um caminho. Por isso, a segurança deve considerar tanto a proteção técnica quanto a conscientização e boas práticas dos usuários.

Como se proteger
- Desconfiar de e-mails e mensagens suspeitas.
- Manter sistemas e softwares atualizados.
- Utilizar senhas fortes e únicas.
- Participar de treinamentos de conscientização.

Professor Rodolfo Terra | linkedin.com/in/rodolffoterra/ | github.com/rodolffoterra/

UniCesumar
EDUCAÇÃO PRESENCIAL E A DISTÂNCIA

BLOCO 04

Pessoas e impactos



Professor Rodolfo Terra | linkedin.com/in/rodolffoterra/ | github.com/rodolffoterra/

UniCesumar
EDUCAÇÃO PRESENCIAL E A DISTÂNCIA

Mapa das principais formas de ataque

Existem diversas formas de ataque que podem ser utilizadas pelos criminosos para comprometer pessoas, sistemas e dados. Abaixo, apresentamos as principais, que serão aprofundadas nas próximas aulas.

Os ataques exploram diferentes fragilidades técnicas e comportamentais e podem ter como objetivo **roubar informações, causar indisponibilidade** ou **obter acesso não autorizado.**

1 Ataques a credenciais



Tentam obter, adivinhar ou roubar credenciais de acesso para invadir sistemas.

Exemplos:
- Força bruta
- Dicionário de senhas
- Credential stuffing
- Ataques a hash de senhas

2 Engenharia social



Manipulam pessoas para obter informações ou induzir ações que favoreçam o atacante.

Exemplos:
- Pretexting
- Baiting (iscas)
- Quid pro quo
- Alvos internos e externos

3 Phishing



Utiliza e-mails, mensagens ou sites falsos para enganar o usuário e roubar informações ou instalar malwares.

Exemplos:
- E-mail phishing
- Spear phishing (ataques direcionados)
- Smishing (SMS)
- Vishing (ligações)

4 Ataques a aplicações web



Exploram vulnerabilidades em aplicações web para obter acesso não autorizado, modificar dados ou executar ações maliciosas.

Exemplos:
- SQL Injection (SQLi)
- Cross-Site Scripting (XSS)
- CSRF
- Falhas de autenticação e autorização

5 Ataques à disponibilidade



Visam tornar sistemas, serviços ou redes indisponíveis, impedindo o acesso de usuários legítimos.

Exemplos:
- DDoS (negação de serviço)
- Inundação de tráfego
- Esgotamento de recursos
- Ataques a infraestrutura de rede

6 Exploração de vulnerabilidades



Aproveitam falhas conhecidas em sistemas, softwares ou configurações para obter acesso não autorizado.

Exemplos:
- Softwares desatualizados
- Falhas de configuração
- Exploração de serviços de rede
- Execução remota de código

Importante

Essas formas de ataque podem ser combinadas. Muitas vezes, o atacante utiliza mais de uma técnica para alcançar seus objetivos.

Objetivos dos ataques
- Roubar informações (dados pessoais, financeiros, credenciais).
- Obter acesso não autorizado a sistemas.
- Causar indisponibilidade (interrupção de serviços).
- Prejudicar a integridade dos dados.
- Gerar impacto para pessoas, organizações e para a sociedade.

Professor Rodolfo Terra | linkedin.com/in/rodolffoterra/ | github.com/rodolffoterra/

UniCesumar
EDUCAÇÃO PRESENCIAL E A DISTÂNCIA

Os riscos para as pessoas

O comprometimento de uma conta, como o e-mail, pode ser o ponto de partida para diversos outros incidentes, afetando múltiplos serviços e causando prejuízos financeiros, perda de dados e danos à reputação.

Muitas contas estão interligadas. Quando uma delas é comprometida, o atacante pode utilizar as mesmas **credenciais** ou os e-mails recebidos para acessar **outros serviços**.

1 Conta de e-mail comprometida



O atacante obtém acesso à conta de e-mail da vítima por meio de phishing, senha fraca ou vazamento de dados.

A partir do e-mail, o atacante pode:

2 Redes sociais

Acessar os perfis, publicar conteúdos indevidos, aplicar golpes nos contatos e prejudicar a reputação.



3 Bancos e serviços financeiros

Recuperar senhas, solicitar redefinições e realizar transações fraudulentas.



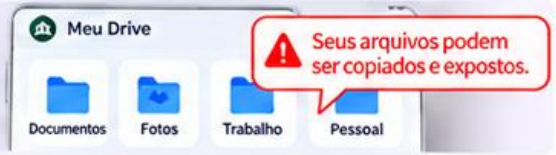
4 Comércio eletrônico

Fazer compras, alterar dados de entrega e utilizar meios de pagamento salvos.



5 Armazenamento em nuvem

Acessar e copiar documentos, fotos e arquivos pessoais ou profissionais.



6 Principais consequências

- Prejuízos financeiros
- Roubo de identidade
- Golpes em contatos
- Vazamento de dados pessoais e profissionais
- Danos à reputação
- Dificuldade para recuperar o acesso

Importante

Uma única conta comprometida pode ser a porta de entrada para diversos outros serviços e causar grandes impactos na vida pessoal e profissional.

Como se proteger

- Utilize senhas fortes e diferentes para cada serviço.
- Ative a autenticação em dois fatores (MFA).
- Desconfie de e-mails e links suspeitos.
- Revise regularmente as permissões de acesso das suas contas.
- Monitore suas contas e ative alertas de segurança.

Professor Rodolfo Terra | linkedin.com/in/rodolffoterra/ | github.com/rodolffoterra/

UniCesumar
EDUCAÇÃO PRESENCIAL E A DISTÂNCIA

Os riscos para as organizações

Incidentes cibernéticos podem gerar uma cadeia de impactos que afetam diretamente os objetivos da empresa, comprometendo a operação, as finanças e a confiança do mercado.

A segurança da informação é essencial para garantir a continuidade do negócio e **proteger o que a organização construiu.**

1 Vazamento de dados



Informações sensíveis da empresa (clientes, parceiros, estratégias) podem ser expostas.

2 Prejuízo financeiro



Multas, custos de recuperação, perda de receita e gastos com segurança.

3 Paralisação das operações



Serviços e processos podem ser interrompidos, afetando a produtividade.

4 Perda de clientes



A confiança dos clientes pode diminuir, levando à perda de negócios.

5 Dano à reputação



A imagem da empresa pode ser afetada, impactando parcerias e mercado.

Impacto nos objetivos do negócio

Esses riscos afetam a capacidade da empresa de operar, crescer e se manter competitiva, colocando em risco a continuidade do negócio.

Por isso, a segurança da informação deve ser prioridade para:

- Proteger os dados
- Manter a confiança
- Assegurar a continuidade
- Preservar a reputação

Investir em segurança é garantir **o futuro do seu negócio.**

Professor Rodolfo Terra | linkedin.com/in/rodolffoterra/ | github.com/rodolffoterra/

UniCesumar
EDUCAÇÃO PRESENCIAL E A DISTÂNCIA

Quando a segurança vira um problema de negócio

Um incidente de segurança pode impactar diretamente a operação de um supermercado, mesmo sem roubo de informações, causando prejuízos financeiros, insatisfação dos clientes e danos à reputação.

A segurança da informação não protege apenas dados, mas também **a continuidade do negócio.**

1 Início do incidente



O supermercado é alvo de um ataque que compromete seus sistemas.

2 Caixas indisponíveis



Os sistemas de frente de caixa param de funcionar, impedindo a realização das vendas.

3 Falhas no pagamento



Cartões e meios de pagamento não são processados, gerando falhas nas transações.

4 Estoque desatualizado



O sistema de estoque fica indisponível ou desatualizado, dificultando a reposição de produtos e a gestão da loja.

5 Clientes impactados



Filas, espera e insatisfação dos clientes, alem de perda de vendas e imagem negativa para o supermercado.

Principais impactos

Mesmo sem haver vazamento de dados, a indisponibilidade dos sistemas pode gerar prejuízos significativos para o negócio.

Consequências para o supermercado

- Perda de receita
- Aumento de custos
- Insatisfação dos clientes
- Perda de parcerias
- Dano à reputação

Lição principal

A segurança da informação é essencial para garantir a continuidade do negócio, mesmo quando não há roubo de informações.

Professor Rodolfo Terra | linkedin.com/in/rodolffoterra/ | github.com/rodolffoterra/

UniCesumar
EDUCAÇÃO PRESENCIAL E A DISTÂNCIA

BLOCO 05

Políticas e prevenção



Professor Rodolfo Terra | linkedin.com/in/rodolffoterra/ | github.com/rodolffoterra/

UniCesumar
EDUCAÇÃO PRESENCIAL E A DISTÂNCIA

O que é uma Política de Segurança da Informação?

A Política de Segurança da Informação (PSI) é um conjunto de regras, diretrizes e responsabilidades que define como a informação deve ser protegida na organização, estabelecendo comportamentos esperados para todos.

A política orienta o uso seguro dos recursos, reduz riscos e contribui para a **continuidade do negócio.**

1 Política de senhas



Define requisitos para criação, uso e troca de senhas, reduzindo o risco de acesso não autorizado.

2 Política de controle de acesso



Estabelece quem pode acessar cada informação ou sistema, com base na necessidade de trabalho.

3 Política de equipamentos



Define regras para o uso de computadores, celulares e demais equipamentos da empresa.

4 Política de backup



Estabelece a realização de cópias de segurança dos dados, garantindo a recuperação em caso de falhas ou incidentes.

5 Política de resposta a incidentes



Define os procedimentos para identificar, tratar e se recuperar de incidentes de segurança.

Ponto importante

Políticas de segurança não dependem apenas de tecnologia. Elas funcionam quando todos conhecem, entendem e seguem as regras estabelecidas.

Elementos de uma boa política

- Regras claras e objetivas
- Responsabilidades definidas
- Aplicação no dia a dia
- Alinhamento com os objetivos do negócio
- Revisão periódica

Resultado

Ambiente mais seguro, com menores riscos e maior continuidade das operações.

Professor Rodolfo Terra | linkedin.com/in/rodolffoterra/ | github.com/rodolffoterra/

UniCesumar
EDUCAÇÃO PRESENCIAL E A DISTÂNCIA

Criar uma política significa estar seguro?

A criação de uma Política de Segurança da Informação é um passo importante, mas não é suficiente. A eficácia depende da comunicação, do treinamento, da aplicação prática e do acompanhamento contínuo.

Uma política no papel não protege a organização.
A segurança só existe quando as pessoas **conhecem, entendem e aplicam as regras** no dia a dia.

Empresa A – Política apenas criada

A empresa elaborou um documento de política, mas não divulgou, não treinou os colaboradores e não acompanha sua aplicação.



- Colaboradores não conhecem a política.
- Não há treinamento ou comunicação.
- As regras não são aplicadas na prática.
- Não existe acompanhamento ou revisão periódica.

Resultado: A política existe apenas no papel.
Os colaboradores continuam adotando práticas de risco e a organização permanece vulnerável a incidentes.

Empresa B – Política implementada

A empresa não apenas criou a política, mas também comunicou, treinou e acompanha sua aplicação de forma contínua.



- Comunicação clara e contínua sobre a política.
- Treinamentos periódicos para todos os colaboradores.
- Aplicação das regras no dia a dia, com apoio da liderança.
- Acompanhamento, métricas e revisão contínua.

Resultado: Os colaboradores conhecem, entendem e aplicam a política.
A organização reduz riscos, aumenta a maturidade em segurança e está mais preparada para prevenir e responder a incidentes.

Lição principal

A criação da política é o primeiro passo.
A segurança depende da conscientização, da prática e do acompanhamento contínuo.

Fatores que aumentam a eficácia da política

- Envolvimento da liderança
- Comunicação constante
- Treinamento regular
- Aplicação no dia a dia
- Monitoramento e melhoria contínua

Objetivo final

Transformar a política de segurança em comportamentos reais e em uma organização mais segura e resiliente.

Professor Rodolfo Terra | linkedin.com/in/rodolffoterra/ | github.com/rodolffoterra/

UniCesumar
EDUCAÇÃO PRESENCIAL E A DISTÂNCIA

Segurança depende de pessoas, processos e tecnologia

A Segurança da Informação é mais eficaz quando pessoas, processos e tecnologia atuam de forma integrada e complementar. Nenhuma ferramenta funciona isoladamente.

A combinação desses três elementos reduz riscos, fortalece a proteção e contribui para a **continuidade do negócio.**



Exemplos de controles

- Treinamentos e conscientização
- Uso seguro de senhas
- Reconhecimento de tentativas de phishing
- Responsabilidade no uso dos recursos
- Comunicação de incidentes



Como os elementos se complementam?

- Pessoas seguem os processos.
- Processos orientam o uso da tecnologia.
- Tecnologia apoia e automatiza os processos.
- Juntos, reduzem riscos e aumentam a resiliência da organização.



Exemplos de controles

- Políticas de segurança da informação
- Gestão de acessos
- Classificação e tratamento da informação
- Gestão de riscos
- Resposta a incidentes
- Auditorias e melhoria contínua





Exemplos de controles

- Firewall e antivírus
- Controle de acesso (MFA)
- Criptografia de dados
- Backup
- Monitoramento e detecção de ameaças
- Atualizações e correção de vulnerabilidades

Ponto importante

Não existe segurança apenas com tecnologia, com pessoas ou apenas com processos. A eficácia está na integração dos três elementos.

Benefícios da abordagem integrada

- Menos riscos de incidentes
- Maior eficiência
- Conformidade com normas
- Continuidade do negócio
- Cultura de segurança

Resultado

Organizações mais seguras, resilientes e preparadas para enfrentar ameaças atuais e futuras.

Professor Rodolfo Terra | linkedin.com/in/rodolffoterra/ | github.com/rodolffoterra/

UniCesumar
EDUCAÇÃO PRESENCIAL E A DISTÂNCIA

Gerenciamento contínuo de riscos

O gerenciamento de riscos de Segurança da Informação é um processo contínuo, pois novas ameaças e vulnerabilidades surgem constantemente, exigindo avaliação, tratamento e monitoramento permanentes.

A Segurança da Informação não é um projeto com início e fim. É um **processo contínuo de avaliação e melhoria.**

1 Identificar os riscos

- Mapear ativos (pessoas, processos, tecnologia e informações)
- Identificar ameaças e vulnerabilidades
- Levantar cenários de risco





2 Analisar os riscos



- Avaliar a probabilidade de ocorrência
- Estimar o impacto no negócio
- Classificar e priorizar os riscos

3 Tratar os riscos



- Definir e implementar controles
- Evitar, reduzir, transferir ou aceitar o risco
- Elaborar planos de ação
- Alocar responsabilidades e recursos

4 Monitorar os riscos



- Acompanhar indicadores e eventos de segurança
- Verificar a efetividade dos controles
- Identificar novos riscos e mudanças no ambiente
- Registrar e reportar os resultados

5 Revisar os riscos



- Reavaliar periodicamente os riscos
- Verificar a eficácia dos controles
- Atualizar o processo com base em novas ameaças e mudanças de ambiente

Ponto importante

Novas ameaças, vulnerabilidades e mudanças no ambiente podem alterar o nível de risco a qualquer momento.

Benefícios do gerenciamento contínuo

- Menor probabilidade de incidentes
- Maior resiliência do negócio
- Uso eficiente de recursos
- Conformidade com normas e regulamentações
- Melhoria contínua

Resultado

Organização mais segura, preparada para enfrentar novas ameaças e com maior capacidade de manter a continuidade do negócio.

Professor Rodolfo Terra | linkedin.com/in/rodolffoterra/ | github.com/rodolffoterra/

UniCesumar
EDUCAÇÃO PRESENCIAL E A DISTÂNCIA

O que fazer com um risco identificado?

Após identificar e analisar os riscos, a organização precisa decidir como tratá-los. Existem diferentes estratégias, e a escolha depende do impacto, da prioridade e da viabilidade de implementação.

Não existe uma única resposta. O tratamento do risco deve considerar o **impacto**, a **prioridade** e a **viabilidade para o negócio**.

1 Aceitar o risco

A organização reconhece o risco e decide não adotar medidas adicionais no momento.



- Quando o impacto é baixo.
- Quando o custo de tratamento é maior que o benefício.
- Requer monitoramento contínuo.

Exemplo empresarial

Aceitar o risco de falha em um sistema interno de baixa criticidade, com pouco impacto no negócio.

2 Mitigar o risco

Implementa medidas para reduzir a probabilidade de ocorrência ou o impacto do risco.



- Controles técnicos, administrativos e operacionais.
- Reduz a chance ou o impacto do incidente.
- É a estratégia mais comum nas organizações.

Exemplo empresarial

Implementar autenticação multifator (MFA) para reduzir o risco de acesso não autorizado aos sistemas.

3 Eliminar o risco

Remove a causa do risco, eliminando a possibilidade de sua ocorrência.



- Elimina a ameaça ou a vulnerabilidade.
- Pode exigir mudanças em processos, tecnologias ou no modelo de negócio.
- Nem sempre é viável em todos os cenários.

Exemplo empresarial

Descontinuar o uso de um sistema legado com vulnerabilidades críticas.

4 Transferir o risco

Compartilha o risco com uma terceira parte, que assume parte ou a totalidade do impacto.



- Transferência por contratos, seguros ou terceirização.
- Reduz o impacto para a organização.
- Não elimina o risco, mas compartilha a responsabilidade.

Exemplo empresarial

Contratar um serviço de segurança em nuvem com SLA e cláusulas de responsabilidade para reduzir o impacto de indisponibilidade.

Fatores para decidir

A escolha da estratégia deve considerar o contexto do negócio e uma análise de custo-benefício.

Principais critérios para a decisão

- Impacto no negócio
- Probabilidade de ocorrência
- Custo de implementação
- Viabilidade técnica
- Prioridade do risco
- Requisitos legais e regulatórios

Resultado

Decisões adequadas sobre o tratamento dos riscos tornam a organização mais segura e resiliente.

Professor Rodolfo Terra | linkedin.com/in/rodolffoterra/ | github.com/rodolffoterra/

UniCesumar
EDUCAÇÃO PRESENCIAL E A DISTÂNCIA

BLOCO 06

Discussão e encerramento



Professor Rodolfo Terra | linkedin.com/in/rodolffoterra/ | github.com/rodolffoterra/

UniCesumar
EDUCAÇÃO PRESENCIAL E A DISTÂNCIA

Situação-problema: uma empresa protegida pode ser invadida?

Mesmo com diversas tecnologias de segurança, uma organização ainda pode ser comprometida. O fator humano continua sendo uma das principais portas de entrada para incidentes de segurança da informação.

Tecnologias de segurança reduzem riscos, mas não eliminam as ameaças. **A conscientização das pessoas** é um elemento essencial.

1 Empresa protegida

A empresa possui diversos controles de segurança implementados.



- Firewall ativo
- Antivírus atualizado
- Backup regular
- Servidores e sistemas atualizados

2 Mensagem falsa

Um colaborador recebe um e-mail aparentemente legítimo solicitando a atualização de suas credenciais.



3 Credenciais comprometidas

O colaborador, acreditando ser uma comunicação real, informa seu usuário e senha no site falso.



4 Acesso do atacante

Com as credenciais, o atacante obtém acesso aos sistemas da empresa e pode realizar ações maliciosas.



5 Impactos gerados

O acesso indevido pode causar diversos danos, mesmo com a infraestrutura protegida.

- Vazamento de dados
- Prejuízo financeiro
- Comprometimento de sistemas
- Interrupção de serviços
- Dano à reputação
- Implicações legais e regulatórias

Onde estava a fragilidade?

- Falta de treinamento e conscientização dos colaboradores.
- Ausência de processos de verificação de comunicações suspeitas.
- Confiança em mensagens aparentemente legítimas (engenharia social).

Quais riscos foram gerados?

- Acesso não autorizado aos sistemas.
- Vazamento de informações sensíveis.
- Uso da conta para novos ataques (internos e externos).
- Possível movimentação lateral na rede da empresa.
- Interrupção de serviços e prejuízos financeiros.

Quais controles podem reduzir a possibilidade do incidente?

- Treinamentos e campanhas de conscientização.
- Simulações de phishing.
- Política de uso de credenciais e autenticação multifator (MFA).
- Processo de verificação de comunicações suspeitas.
- Monitoramento de atividades e detecção de comportamentos anômalos.
- Cultura de segurança e canal para reporte de incidentes.

Conclusão

Uma empresa pode ser invadida mesmo com tecnologias de segurança implementadas, quando o fator humano não recebe a devida atenção. O objetivo não é identificar culpados, mas compreender que **a segurança é uma responsabilidade compartilhada** e que a **conscientização dos colaboradores** é **fundamental** para reduzir riscos e proteger o negócio.

Professor Rodolfo Terra | linkedin.com/in/rodolffoterra/ | github.com/rodolffoterra/

UniCesumar
EDUCAÇÃO PRESENCIAL E A DISTÂNCIA

Mapa mental – Conceitos e relacionamentos

Entenda como os principais conceitos da Segurança da Informação se conectam e formam um ciclo contínuo, sustentado por pessoas, processos e tecnologia.

AMEAÇAS

Algo que pode explorar uma vulnerabilidade.

- Malware
- Engenharia Social
- Acessos não autorizados
- DDoS
- Ameaças internas

exploram

VULNERABILIDADES

Fraquezas que podem ser exploradas.

- Sistemas desatualizados
- Configurações inadequadas
- Falta de treinamento
- Processos falhos
- Falta de controle de acesso

permitem

ATAQUES

Ação que explora uma vulnerabilidade.

- Phishing
- Exploits
- Uso de credenciais
- Injeção de código
- Movimentação lateral

podem causar

IMPACTOS

Consequências para a organização.

- Vazamento de dados
- Prejuízo financeiro
- Paralisação de serviços
- Perda de clientes
- Dano à reputação
- Consequências legais

geram

RISCOS

Possibilidade de um impacto acontecer.

- Probabilidade
- Impacto
- Prioridade
- Avaliação de cenários
- Suporte à tomada de decisão

são tratados por

GERENCIAMENTO CONTÍNUO DE RISCOS

Identificar, analisar, tratar, monitorar e revisar.

Identificar → Analisar → Tratar → Monitorar → Revisar

SEGURANÇA DA INFORMAÇÃO

Proteger o negócio, reduzindo riscos e garantindo a continuidade.

SUSTENTADA POR

PESSOAS

Comportamento, conhecimento e responsabilidade.

- Treinamento
- Conscientização
- Cultura de segurança
- Uso responsável dos recursos

PROCESSOS

Regras, procedimentos e governança.

- Políticas de segurança
- Gestão de acessos
- Gestão de riscos
- Resposta a incidentes
- Auditorias e melhoria contínua

TECNOLOGIA

Ferramentas e infraestrutura de proteção.

- Firewall e antivírus
- Controle de acesso (MFA)
- Criptografia
- Backup
- Monitoramento e detecção

Mensagem principal

Uma organização **não está segura porque** nunca foi atacada.
Ela está mais segura quando **conhece seus riscos**, **reduz suas vulnerabilidades**, **prepara suas pessoas** e **está pronta para responder** quando um incidente acontecer.

Professor Rodolfo Terra | linkedin.com/in/rodolffoterra/ | github.com/rodolffoterra/

Bons estudos!

Siga em frente com a



www.unicesumar.edu.br